

Segurança da Informação e LGPD

Campo Grande, 29/08/2026

Prof. Dr. Carlos Alberto da Silva

Faculdade de Computação (FACOM) - UFMS

Professor Associado da FACOM, e possui Graduação, Mestrado e Doutorado em Ciência da Computação, área de pesquisa em Segurança da Informação, ênfase em Segurança de Nuvem Computacional.

E-mail: carlos.silva@ufms.br



Tópicos

- **Segurança da Informação**
 - Conceito e prática
- **Princípios de segurança**
 - Confidencialidade, Integridade, e Disponibilidade
- **Políticas de segurança**
- **LGDP**

Segurança da Informação



Segurança da Informação é a prática de proteger dados contra acesso, uso, divulgação, alteração ou destruição não autorizados.

- Ela se baseia em **pilares fundamentais**: Confidencialidade, Integridade, Disponibilidade e Autenticidade.
- As bases desse **ecossistema** para manter seus sistemas seguros (hardware, software e peopleware).

Exemplo de Segurança da Informação



Segurança da Informação



Segurança da Informação



Princípios de segurança



Tríade CID (O núcleo da Segurança)

- **Confidencialidade:** garante que a informação seja acessível apenas por pessoas ou sistemas autorizados.
- **Integridade:** assegura que a informação não foi alterada ou corrompida durante o armazenamento ou transmissão.
- **Disponibilidade:** garante que a informação e os sistemas estejam prontos para serem utilizados sempre que os usuários autorizados precisarem deles.

Tríade CID (O núcleo da Segurança)

- **Confidencialidade**
- **Integridade**
- **Disponibilidade**



Autenticidade e Identidade

- **Definição:** é a garantia de que a identidade de um usuário, sistema ou documento é legítima e provém da fonte anunciada.
- **Mecanismos:** válida por meio de algo que você sabe (senha), algo que você tem (token) ou algo que você é (biometria).
- **Evitar:** Falsidade, Falsificação, Impostura, ...



Defesa em Profundidade

- **Defesa em Camadas:** A aplicação conjunta desses princípios cria barreiras sucessivas garantindo:
 - **Criptografia** para Confidencialidade.
 - **Hashing** para Integridade.
 - **Redundância** para Disponibilidade.
 - **Assinatura Digital** para Não-Repúdio.

Políticas de segurança

Controles da nova ISO 27002

5.1 Política de Segurança da Informação

Intenções e direção da organização, expressa formalmente por sua Alta Direção



Políticas específicas por tema

Intenções e direção sobre um assunto ou tema específico, estabelecidas pelo nível apropriado de gestão

controle de acesso	segurança física e do ambiente	gestão de ativos	transferência de informações	configuração e manuseio seguros de dispositivos endpoint do usuário	segurança de redes	gestão de incidentes de segurança da informação	backup	criptografia e gerenciamento de chaves	classificação e tratamentos de informações	gestão de vulnerabilidades técnicas	desenvolvimento seguro
--------------------	--------------------------------	------------------	------------------------------	---	--------------------	---	--------	--	--	-------------------------------------	------------------------

é um **documento formal** que define as regras, diretrizes e responsabilidades para proteger os dados, sistemas e redes de uma organização.

- Princípios fundamentais (CID)
- Regras de conduta
- Gestão de incidentes
- Conformidade legal: Alinha a empresa a legislações como a **LGPD** e a normas internacionais como a ISO/IEC 27001.

Lei Geral de Proteção dos Dados (LGPD)

O que é a LGPD ?

A Lei Geral de Proteção de Dados (**Lei nº 13.709/2018**) estabelece as regras para o tratamento de dados pessoais no Brasil, tanto em meios físicos quanto digitais.

Objetivo principal: proteger os direitos fundamentais de privacidade e liberdade, devolvendo aos cidadãos o controle sobre suas informações.

Exemplos:



Exemplos:



Exemplos:



Principais Objetivos

- **Dar controle ao cidadão** sobre suas próprias informações (como nome, CPF e endereço).
- **Exigir transparência das empresas** ao usar esses dados.
- **Evitar vazamentos e o uso ruim ou ilegal** de informações pessoais.

Quem cuida da lei ?

A fiscalização e a criação de regras oficiais no país são feitas pela **ANPD** (Autoridade Nacional de Proteção de Dados).

- Seus direitos como **donos dos dados**
- Como uma **empresa** deve se adequar
- O papel do **Encarregado de dados** (DPO)

Impacto no software (desenvolvimento e manutenção)

⇒ Mudar a mentalidade de **"coletar tudo o que for possível"** para **"coletar estritamente o necessário"**.

Dados pessoais x dados sensíveis

- **Dado pessoal:** qualquer informação relacionada a uma pessoa viva identificada ou identificável (exemplo: nome, CPF, e-mail, IP, geolocalização, endereço, etc).
- **Dado pessoal sensível:** dado que exige mais proteção por estar sujeito à discriminação (exemplo: origem racial, convicção religiosa, dados de saúde, biometria, etc).

Princípios fundamentais do tratamento:

- **Finalidade:** o software deve coletar dados para propósitos legítimos, específicos e informados explicitamente ao usuário;
- **Necessidade (minimização):** limitação do tratamento ao mínimo necessário para a execução do serviço (s/ excessos).
- **Transparência:** garantia de informações claras e acessíveis; sobre o uso dos dados diretamente na interface (políticas de privacidade legíveis).

Bases Legais para Coleta de Dados

- **Justificativas jurídicas** que autorizam o software a armazenar um dado. Sem uma base legal, o tratamento é ilegal;
- **Consentimento**: manifestação livre e inequívoca do usuário (exemplo: caixas de seleção opt-in não marcadas previamente).

Bases Legais para coleta de dados:

- **Execução de contrato:** quando o dado é necessário para entregar o serviço contratado;
- **Cumprimento de obrigação legal:** armazenamento exigido por outras leis (como o Marco Civil da Internet, arquivo do log).

Bases Legais para coleta de dados:

Direitos dos titulares de dados

- **Acesso e confirmação:** o usuário tem o direito de saber se o sistema trata seus dados e obter uma cópia deles;
- **Correção:** atualização de dados incompletos, inexatos ou desatualizados nas telas de perfil;

Bases Legais para coleta de dados:

Direitos dos titulares de dados:

- **Portabilidade:** direito de transferir seus dados para outro fornecedor de serviços;
- **Revogação:** o usuário pode mudar de ideia e **retirar o consentimento fornecido anteriormente**.

Bases Legais para coleta de dados:

Atores do tratamento de dados:

- **Titular:** a pessoa física a quem os dados pessoais se referem (o usuário final do seu sistema);
- **Controlador:** quem toma as decisões sobre o tratamento (a instituição, ONG ou empresa que utiliza o software);

Bases Legais para coleta de dados:

Atores do tratamento de dados

- **Operador:** quem executa o tratamento em nome do controlador (exemplo: o serviço de nuvem, onde seu banco de dados está hospedado);
- **Encarregado:** o canal de comunicação entre o controlador, os titulares e a ANPD.

Bases Legais para coleta de dados:

O direito à eliminação (Artigo 18)

- **Requisito:** o titular tem o direito de exigir a exclusão definitiva de seus dados pessoais tratados com base no consentimento;
- **Desafio no desenvolvimento:** o botão "excluir conta" não pode ser apenas estético.
 - Disparar **queries de deleção** (DELETE ou anonimização) reais no banco de dados;

Bases Legais para coleta de dados:

O direito à eliminação (Artigo 18):

- **Exceções legais:** os dados podem ser retidos mesmo após o pedido, se houver obrigação legal;
- **Exemplo:** guardar logs de acesso por 6 meses, conforme o Marco Civil da Internet.

O que é a ANPD?

- **Definição:** a Autoridade Nacional de Proteção de Dados (ANPD) é uma autarquia federal responsável por zelar pela proteção de dados pessoais no Brasil;
- **Relação com a LGPD:** enquanto a LGPD é a lei (o texto normativo), a ANPD é o órgão que garante, fiscaliza e orienta para que a lei seja cumprida na prática.

Principais atribuições da ANPD:

- **Regulamentação:** elaborar diretrizes, guias práticos e regras específicas para preencher lacunas técnicas da lei;
- **Fiscalização e sanção:** ouvir denúncias de titulares, auditar empresas e aplicar punições administrativas em caso de vazamentos ou descumprimento;
- **Função educativa:** promover o conhecimento na sociedade sobre a proteção de dados (essencial para ações de extensão).

Sanções e penalidades administrativas

- **Advertência:** notificação formal fixando prazo para correção de falhas no sistema;
- **Multa simples:** pode chegar a 2% do faturamento da empresa, limitada a R\$ 50 milhões por infração;
- **Bloqueio/eliminação:** bloqueio temporário ou exclusão total dos dados pessoais da base do sistema, inviabilizando a operação do software.

Normas e Resoluções publicadas pela ANPD:

- **Dosimetria de sanções:** estabelece critérios de como as multas serão calculadas com base na gravidade do vazamento;
- **Agentes de pequeno porte:** regulamentação que flexibiliza e simplifica obrigações para startups, micro empresas e organizações sem fins lucrativos (ONGs);

Normas e Resoluções publicadas pela ANPD:

- **Comunicação de Incidentes:** prazos e regras de como relatar à ANPD quando o banco de dados do sistema sofrer uma invasão;

⇒ ***Privacy by design*** como parte da arquitetura inicial do código.

Estatutos no Brasil:

- ECA significa **Estatuto da Criança e do Adolescente**, criado no Brasil pela **Lei nº 8.069** em 13 de julho de 1990.
 - protege os direitos fundamentais de quem tem até 18 anos de idade.
 - crianças (até 12 anos incompletos)
 - e adolescentes como sujeitos de direitos e pessoas em pleno desenvolvimento.

Estatutos no Brasil:

- **ECA** significa **Estatuto da Criança e do Adolescente**
 - **Proteção integral**: garante prioridade absoluta em saúde, educação, convivência familiar e lazer.
 - **Dever de todos**: a família, a sociedade e o Estado devem assegurar o bem-estar e evitar qualquer forma de violência ou negligência.
 - **Proibição**: veda o trabalho infantil e pune a omissão diante de maus-tratos.
- **ECA Digital**: atualizado recentemente para obrigar redes sociais e jogos eletrônicos a protegerem menores contra violência online e uso de dados inadequados.

Estatutos no Brasil:

- **Estatuto da Pessoa Idosa (Lei nº 10.741/2003)** é a legislação brasileira que protege e regula os direitos das pessoas com 60 anos ou mais.
- **Objetivo:** garantir proteção integral, direitos fundamentais e a participação ativa dos idosos na sociedade.
- **Responsabilidade:** a família, a sociedade e o Estado têm o dever compartilhado de amparar a pessoa idosa e garantir seu bem-estar.

Estatutos no Brasil:

- Estatuto da Pessoa Idosa (Lei nº 10.741/2003)
 - Principais Direitos e Garantias
 - **Saúde e Vida:** atendimento preferencial e acesso a políticas públicas para um envelhecimento saudável.
 - **Prioridade em Processos**
 - **Transporte**
 - **Respeito e Dignidade**

Estudos de casos

PIX anonimização

Exemplo



Exemplo



Referências



BRASIL. Lei nº 13.709, de 14 de agosto de 2018. **Lei Geral de Proteção de Dados Pessoais (LGPD)**. Brasília: Presidência da República. Disponível em: <https://link.ufms.br/lmh6Z>. Acesso em: 19 jun. 2026.

BRASIL. Lei nº 10.741, de 1º de outubro de 2003. **Estatuto do Idoso** e dá outras providências. Diário Oficial da União, Brasília, DF, 3 out. 2003.

BRASIL. Lei nº 8.069, de 13 de julho de 1990. **Estatuto da Criança e do Adolescente** e dá outras providências. Diário Oficial [da] República Federativa do Brasil, Brasília, DF, 16 jul. 1990.

INTERNATIONAL ORGANIZATION FOR STANDARDIZATION (ISO). **ISO/IEC 27001: Information security management systems — Requirements**. Disponível em: <https://www.iso.org/isoiec-27001-information-security.html>. Acesso em: 24 abr. 2026.

Licenciamento



Respeitadas as formas de citação formal de autores de acordo com as normas da ABNT NBR 6023 (2018), a não ser que esteja indicado de outra forma, todo material desta apresentação está licenciado sob uma [Licença Creative Commons - Atribuição 4.0 Internacional](https://creativecommons.org/licenses/by/4.0/).

